AUDITORIA COMPLETA DE SEGURANÇA

Repositório Canal Tá Barato
Revisão técnica somente leitura

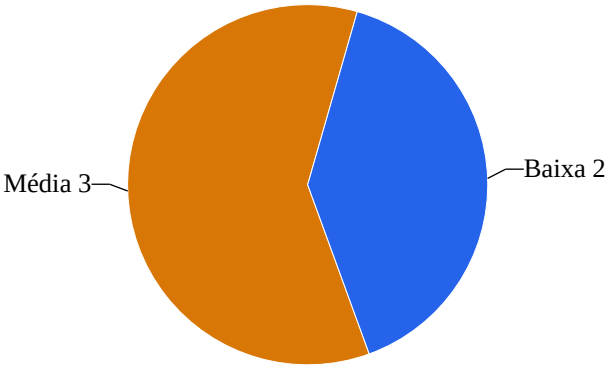
Data	Referência auditada	Natureza	Classificação
15/09/2026	origin/main @ aa9c8a7	Estática + testes locais	Uso interno

Este documento não contém valores integrais de tokens, chaves, IDs pessoais ou credenciais. Não houve teste ativo contra produção, envio real, alteração de dados, configuração externa ou remediação de código.

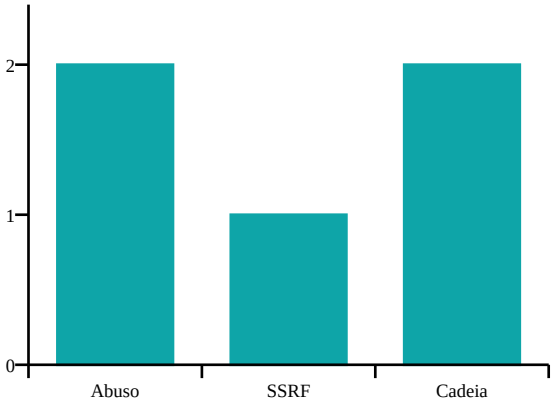
Resumo executivo

Conclusão: a base apresenta boas barreiras em autenticação administrativa, consultas D1 parametrizadas, escape de conteúdo e proteção de segredos. Não foram confirmadas falhas críticas ou altas. Foram confirmados **cinco achados acionáveis**: três médios e dois baixos. Outros três pontos dependem de configuração ou condições externas e permanecem como **PRECISA DE CONFIRMAÇÃO**.

Achados confirmados por severidade



Itens por área (inclui confirmação)



Sem achados críticos ou altos confirmados. O alerta upstream alto de sharp foi reclassificado como médio pelo contexto dev/CI.

Severidade	Confirmados	Leitura executiva
CRÍTICA	0	Nenhum achado.
ALTA	0	Nenhum achado confirmado.
MÉDIA	3	Integridade da vitrine, métricas/custo e cadeia dev/CI.
BAIXA	2	Hardening da cadeia de CI e limite de corpo em feedback.
Confirmação	3	SSRF por DNS rebinding, segredo Meta e controles externos.

Prioridades

• **P0:** nenhum item crítico/alto confirmado.

• **P1:** proteger o fluxo de feedback; tornar telemetria/cliques resistentes a automação; atualizar a cadeia Wrangler/sharp.

• **P2:** pinagem imutável de Actions; limitar corpo real do feedback; fechar a janela de DNS rebinding; validar segredos e controles externos.

Escopo, método e limitações

A árvore local estava em um commit anterior e a referência remota local **origin/main** continha a implementação atual do site e integrações. Para evitar alterar o checkout, a revisão estática leu os objetos Git de **origin/main @ aa9c8a7** diretamente. Uma cópia efêmera em /tmp foi usada somente para testes; não integra os artefatos entregues.

Incluído	Como foi verificado
Código Python, Workers e Pages Functions	Leitura sistemática de fluxos, handlers, validações, sinks, queries e integrações.
Git e histórico	Busca de padrões de segredos no histórico completo, com mascaramento e triagem manual.
CI/CD e dependências	Workflows, permissões, lockfile, resolução Python 3.12 e bancos públicos de advisories.
Testes locais	217 testes Python, 43 JavaScript e verificação sintática de todos os JS do site - todos passaram na referência auditada.
Fora do alcance	Produção, painéis Cloudflare/GitHub/Meta, DNS, WAF, secrets reais, dados reais e testes ofensivos externos.

Método

• Mapeamento de arquitetura, dados, identidades e fronteiras de confiança.

• Inventário dos endpoints públicos e administrativos; rastreamento de entrada até uso em SQL, HTML, URLs, logs e APIs.

• Revisão alinhada a OWASP Top 10, OWASP API Security, CWE e práticas Cloudflare Workers/D1.

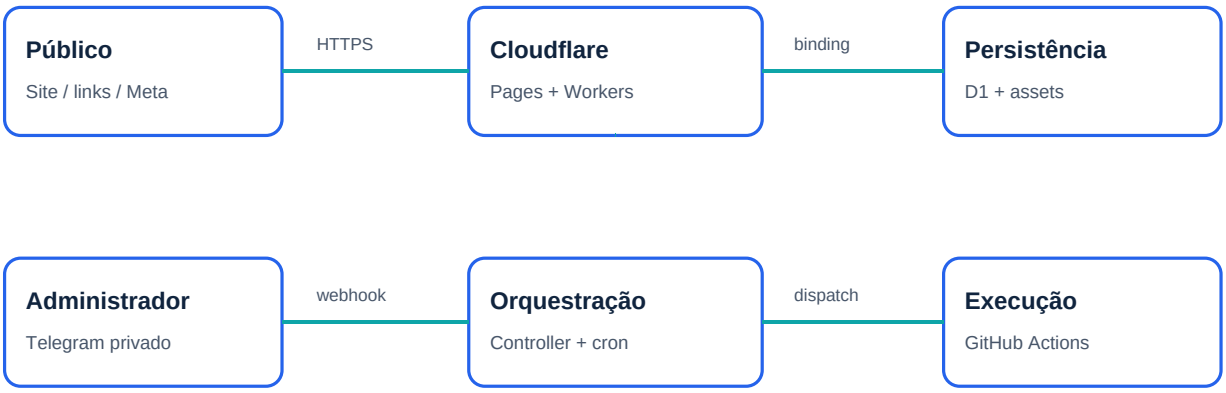
• Classificação por evidência: CONFIRMADA, PRECISA DE CONFIRMAÇÃO, PASSOU ou N/A.

• Sem alteração de código, configuração, dados, Git ou serviços externos.

Limitações que afetam a certeza

Não foi possível confirmar secrets/variables efetivos, configuração do projeto Pages, WAF/Rate Limiting, HSTS no edge, proteções de branch, Dependabot, permissões organizacionais ou versões já instaladas em execuções históricas. Tais itens não foram presumidos como vulneráveis.

Arquitetura e modelo de isolamento



O produto não possui contas de usuários nem tenants. A vitrine é pública; favoritos ficam no navegador. O domínio administrativo é de operador único: Telegram privado → Worker controlador → GitHub Actions/variáveis. D1 é acessível por bindings dos Workers, não diretamente pelo navegador.

Camada	Dados / credenciais	Controle observado
Site público	Ofertas, lojas, cupons, contadores	Leitura pública; mutações editoriais exigem Bearer.
Meta webhook	Eventos Direct e hash temporário	HMAC do corpo; allowlist de conta quando configurada; retenção de 48 h.
Redirector	Slugs, destinos e cliques	Admin Bearer ≥32 caracteres; destino HTTPS/hosts; leitura pública.
Telegram controller	Configurações operacionais	Secret de webhook + chat privado + actor ID; segredo interno no fallback cron.
GitHub Actions	Credenciais de marketplaces/canais e estado cifrado	Secrets/vars; permissões read; estado autenticado e criptografado.

RLS e multi-tenancy

N/A. Não há PostgreSQL/Supabase/Firebase nem separação por organização. Para D1, o equivalente relevante é a exposição indireta por handlers: as mutações administrativas verificam autorização no servidor. Não foi encontrado IDOR sobre dados privados; IDs públicos apontam apenas para catálogo público.

Resultado por categoria obrigatória

Categoria	Status	Conclusão
1. Isolamento / RLS	PASSOU / N/A	D1 apenas via Worker; sem tenants; autorização manual nas mutações.
2. Autorização frontend	PASSOU	Nenhuma operação sensível depende apenas da interface.
3. IDOR	PASSOU	IDs públicos são de catálogo; endpoints administrativos revalidam Bearer.
4. Segredos	PASSOU	Nenhum segredo real confirmado no código ou histórico; exemplo encontrado era placeholder.
5. Inputs / injeções / SSRF / upload	PRECISA DE CONFIRMAÇÃO	SQL parametrizado e HTML escapado; risco condicional de DNS rebinding em imagem externa.
6. Autenticação / sessão / CSRF	PASSOU / N/A	Admin fail-closed e comparações por digest; sem sessão/senha. Meta GET depende de secret externo.
7. Rate limiting / abuso	CONFIRMADA	Feedback e telemetria pública permitem automação e escrita D1 sem limitação visível.
8. Configuração / dependências / CI	CONFIRMADA	Dependência dev/CI vulnerável e Actions por tag mutável; Python limpo na resolução atual.

Pontos fortes observados

• Consultas D1 preparadas e valores dinâmicos limitados a mapas internos; não foi encontrada injeção SQL.

• Escape consistente de conteúdo em HTML/JSON-LD e CSP nas respostas HTML; não foi encontrada XSS explorável.

• Tokens administrativos falham fechados; Telegram exige segredo do webhook, conversa privada e ID do ator.

• Webhook Meta POST valida HMAC sobre bytes limitados, limita eventos e deduplica por hash sem guardar texto/perfil.

• Upload administrativo limita tamanho, exige JPEG e publica por identificador aleatório; não há upload de usuário final.

• Estado remoto é cifrado e autenticado; logs aplicam redação; nenhum segredo real foi confirmado no histórico Git.

• Workflows têm permissões reduzidas e não usam pull_request_target nem executam segredos em PR.

Achados confirmados

SEC-01 - Feedback público permite derrubar ofertas por automação

Status	Severidade	Referência	Confiança
CONFIRMADA	MÉDIA	CWE-799 / OWASP API6:2023	Alta

CONFIRMADA

Evidência

site/functions/api/feedback.js:3-13 aceita qualquer cliente que declare Origin/Sec-Fetch-Site esperados e incrementa um contador. **site/functions/api/offers.js:13** e **site/functions/_discovery.js:33** ocultam ofertas após cinco relatos; o bloqueio local do navegador não é controle servidor.

Cenário de exploração

Um cliente não navegador envia repetidamente POSTs com cabeçalhos forjados para IDs de ofertas públicos até atingir o limiar. Não exige conta, token, IP estável ou interação humana.

Impacto

Perda de integridade e disponibilidade do catálogo: ofertas válidas podem desaparecer da vitrine e das páginas de descoberta. Também há escrita D1 controlada externamente.

Correção mínima segura

Aplicar rate limit no edge e deduplicação server-side com identificador efêmero/privacidade preservada; não permitir que contagem bruta suprima automaticamente sem janela, confiança ou revisão. Origin deve permanecer defesa de navegador, não identidade.

Como validar depois

Teste automatizado deve provar que repetições da mesma origem lógica não avançam o limiar e que abuso distribuído é limitado. Confirmar que cinco chamadas simples não removem uma oferta válida.

SEC-02 - Telemetria e cliques públicos são manipuláveis e amplificam escritas D1

Status	Severidade	Referência	Confiança
CONFIRMADA	MÉDIA	CWE-799 / OWASP API4:2023	Alta

CONFIRMADA

Evidência

site/functions/api/view.js:10-31 incrementa visualizações/fontes em cada POST. **go/[id].js:2-9**, **cupom/[id].js:3-12**, **loja/[slug].js:3-11**, **story-go/[id].js:23-31** e **redirector/src/index.js:90-105** escrevem clique a cada acesso válido. IDs e slugs são públicos. Não há rate limit ou deduplicação no repositório.

Cenário de exploração

Um robô percorre links públicos ou repete /api/view. Cada chamada válida produz uma ou mais escritas. Contagens alimentam relatórios e ordenação por popularidade.

Impacto

Métricas e ranking podem ser envenenados; a carga de escrita/custo D1 pode crescer artificialmente. O resultado comercial deixa de representar tráfego real.

Correção mínima segura

Aplicar rate limiting/bot management no edge; agregar/deduplicar em janela curta com chave que preserve privacidade; separar telemetria não confiável de sinais usados em ranking. Para /api/view, exigir JSON e usar leitura limitada antes do parse.

Como validar depois

Executar rajadas controladas em ambiente local/staging e confirmar 429/queda de escrita; verificar que contagens repetidas não influenciam ranking dentro da janela.

SEC-03 - Lockfile inclui sharp vulnerável na cadeia Wrangler/miniflare

Status	Severidade	Referência	Confiança
CONFIRMADA	MÉDIA	CWE-1104 / GHSA-rgj7-g3m4-5g8c	Alta

CONFIRMADA

Evidência

telegram-control/pnpm-lock.yaml:454, 793-795, 808 fixa **sharp 0.35.2** via wrangler → miniflare. A auditoria do registry reportou advisory alto de libheif para sharp <0.35.4. O pacote é de desenvolvimento/CI e não compõe o código executado no Worker.

Cenário de exploração

Conteúdo de imagem especialmente criado teria de alcançar uma operação vulnerável de sharp durante desenvolvimento/testes/ferramentas. Não foi identificado fluxo de entrada não confiável no CI atual, reduzindo a probabilidade.

Impacto

Comprometimento ou falha de disponibilidade de runner/estação se uma rota de processamento aplicável for introduzida ou já existir fora do código analisado. Risco de produção direta não foi evidenciado.

Correção mínima segura

Atualizar Wrangler/miniflare para uma resolução que use sharp ≥0.35.4, ou aplicar override compatível; regenerar o lockfile e preservar integridade hashes. Validar changelog e compatibilidade Worker.

Como validar depois

Executar pnpm audit até zerar o advisory, instalar com lockfile congelado e rodar todos os 43 testes JS e o check sintático.

SEC-04 - GitHub Actions referenciadas por tags mutáveis

Status	Severidade	Referência	Confiança
CONFIRMADA	BAIXA	CWE-829 / OWASP CI/CD-SEC-4	Alta

CONFIRMADA

Evidência

.github/workflows/ci.yml:16-17,23, **bot.yml:163,165,207** e **monitor.yml:24-25** usam actions/checkout@v5, setup-python@v6, setup-node@v5 e upload-artifact@v7 sem SHA completo.

Cenário de exploração

Se uma tag upstream for movida ou a conta/publicação for comprometida, o workflow pode executar conteúdo diferente do revisado. São Actions oficiais, o que reduz - mas não elimina - o risco.

Impacto

Comprometimento da cadeia de CI, com acesso aos secrets disponibilizados no job do bot e ao GITHUB_TOKEN dentro das permissões concedidas.

Correção mínima segura

Fixar cada Action no SHA completo de release verificado e manter comentário com a versão humana. Automatizar atualizações via Dependabot/Renovate com revisão.

Como validar depois

Confirmar que os workflows usam SHAs de 40 caracteres, passam nos testes e que o SHA corresponde ao release oficial pretendido.

SEC-05 - Limite de corpo do feedback depende de Content-Length declaratório

Status	Severidade	Referência	Confiança
CONFIRMADA	BAIXA	CWE-400	Alta

CONFIRMADA

Evidência

site/functions/api/feedback.js:7-8 rejeita Content-Length >2 KiB, mas depois chama request.json() diretamente. Um cliente pode omitir ou falsear o cabeçalho e enviar corpo muito maior até o limite da plataforma.

Cenário de exploração

Um cliente transmite JSON grande sem Content-Length correto. O Worker materializa o corpo antes de validar os dois campos úteis.

Impacto

Consumo desnecessário de memória/CPU por requisição e maior exposição a negação de serviço; o limite máximo da plataforma reduz o teto do impacto.

Correção mínima segura

Trocar request.json() por readJsonLimited(request, 2048), já disponível em site/functions/_lib.js:25-27, mantendo Content-Length apenas como rejeição antecipada.

Como validar depois

Adicionar testes com corpo acima de 2 KiB sem Content-Length e com cabeçalho subestimado; ambos devem retornar 413 sem escrita D1.

Itens que precisam de confirmação

CONF-01 - Validação DNS e download de imagem ocorrem em resoluções separadas

Status	Severidade	Referência	Confiança
PRECISA DE CONFIRMAÇÃO	MÉDIA	CWE-918	Média

PRECISA DE CONFIRMAÇÃO

Evidência

seguranca.py:36-51 resolve e aprova somente IPs globais; depois **bluesky.py:71-80** inicia requests.get por hostname, permitindo nova resolução DNS (janela TOCTOU). Redirecionamentos são desativados e o corpo é limitado a 1 MiB, controles positivos.

Cenário de exploração

Um domínio controlado alterna DNS entre IP global na validação e endereço privado no download. A exploração depende de uma fonte de marketplace permitir hostname controlado e de o runner alcançar um serviço interno útil.

Impacto

Possível SSRF de leitura a partir do runner. Não foi possível provar controle do hostname nem alcançabilidade interna sem testar integrações externas.

Correção mínima segura

Preferir allowlist de CDNs oficiais por marketplace. Quando necessário aceitar hosts arbitrários, vincular conexão ao IP validado com verificação TLS/SNI correta e revalidar cada conexão.

Como validar depois

Em staging, usar DNS controlado para simular rebinding e confirmar que o socket não alcança IP privado; adicionar teste unitário da abstração de transporte.

CONF-02 - Verificação GET do webhook Meta pode aceitar token ausente se o secret não existir

Status	Severidade	Referência	Confiança
PRECISA DE CONFIRMAÇÃO	BAIXA	CWE-306	Média

PRECISA DE CONFIRMAÇÃO

Evidência

site/functions/api/meta-webhook.js:6-21 normaliza valores ausentes para string vazia e compara os digests. Se META_WEBHOOK_VERIFY_TOKEN estiver ausente e a requisição também omitir hub.verify_token, a condição pode aceitar mode=subscribe e challenge. O valor efetivamente configurado no Pages não está versionado.

Cenário de exploração

Um terceiro envia o handshake sem token. O efeito útil depende de o secret estar ausente e de controle/configuração da assinatura do app Meta, não demonstrados.

Impacto

Bypass do segredo de verificação no cenário de implantação incompleta; não concede capacidade de forjar POST, que continua protegido por HMAC.

Correção mínima segura

Exigir explicitamente secret e token não vazios antes da comparação; falhar a implantação/health check quando variáveis Meta necessárias estiverem incompletas.

Como validar depois

Remover o secret em ambiente local e confirmar 403 mesmo com challenge; com secret válido, testar sucesso apenas para token idêntico.

CONF-03 - Controles de edge e configuração implantada não são demonstráveis pelo repositório

Status	Severidade	Referência	Confiança
PRECISA DE CONFIRMAÇÃO	BAIXA	Configuração externa	Média

PRECISA DE CONFIRMAÇÃO

Evidência

O repositório contém **site/wrangler.toml.example**, não a configuração Pages efetiva. Não há evidência local de WAF/rate limiting, HSTS, rotação de secrets, proteção de branch, Dependabot ou valores obrigatórios implantados. A ausência no Git não prova ausência na plataforma.

Cenário de exploração

Se esses controles estiverem desativados, os achados de abuso têm maior probabilidade/impacto e falhas de configuração podem persistir sem alerta.

Impacto

Maior exposição a automação, downgrade inicial de HTTPS em clientes sem preload e deriva de configuração/credenciais.

Correção mínima segura

Auditar painéis Cloudflare/GitHub em sessão autorizada; documentar baseline declarativo sem copiar valores secretos; validar secret scanning, branch protection, HSTS e regras de rate limit.

Como validar depois

Exportar evidências não sensíveis (nomes de regras, status, datas de rotação, checks exigidos) e anexar ao ticket sem IDs pessoais ou valores de secret.

Segredos, histórico e dependências

A busca percorreu os patches do histórico Git e a árvore atual com padrões de chaves privadas, tokens de provedores, Authorization, arquivos .env e credenciais usuais. Um texto com formato semelhante a token Telegram em documentação histórica foi triado como **placeholder sintético**; não é segredo real. Ocorrências em testes eram valores fictícios. Nenhum valor integral é reproduzido neste relatório.

Verificação	Resultado	Observação
Segredos reais no HEAD/histórico	PASSOU	Nenhum confirmado; .env real e chaves privadas não foram encontrados.
Python no CI (3.12)	PASSOU	Resolução atual: requests 2.34.2, python-dotenv 1.2.3, cryptography 50.0.1, Pillow 12.3.0; pip-audit sem vulnerabilidades conhecidas.
Node lockfile	FALHOU	1 advisory alto upstream em sharp 0.35.2, transitivo de Wrangler/miniflare; contexto dev/CI.
Reprodutibilidade Python	OBSERVAÇÃO	requirements usa limites mínimos, sem lock; a resolução futura pode mudar entre execuções.

Nota de severidade

O advisory upstream de sharp é classificado como alto pelo registry. Neste projeto foi classificado como **MÉDIO** porque a dependência está em devDependencies e não foi encontrado processamento de imagens não confiáveis por Wrangler/miniflare no CI. Se essa premissa mudar, a severidade deve ser reavaliada para alta.

N/A explícitos

• RLS PostgreSQL/Supabase e Firebase Rules; não existem no stack.

• Cadastro, login, cookies de sessão, recuperação de senha, MFA e CSRF de conta; o produto não tem contas.

• Isolamento entre organizações/usuários; arquitetura de operador único e catálogo público.

• Upload de usuário final; somente upload administrativo de JPEG foi encontrado e passou nos controles revisados.

• Docker, Kubernetes, Helm, Terraform, filas de mensagens próprias e pagamentos; não encontrados.

Plano de correção priorizado

Prazo	Ação	Risco mitigado	Dependência
P1 - imediato	Rate limit + deduplicação/revisão do feedback	Supressão indevida de ofertas	Regra Cloudflare + ajuste de função/D1
P1 - imediato	Rate limit/dedup de view e cliques; leitura limitada	Envenenamento de métricas e custo	Cloudflare + funções
P1 - imediato	Atualizar Wrangler/miniflare/sharp	Advisory na cadeia dev/CI	Regenerar lockfile e testes
P2 - curto	Pinagem de Actions por SHA	Supply chain de workflow	Revisão de releases
P2 - curto	readJsonLimited no feedback	Corpo excessivo	Teste de 413
P2 - curto	Allowlist/pinning seguro para imagens	SSRF por DNS rebinding	Confirmar hosts de marketplaces
P2 - curto	Fail-closed explícito no GET Meta	Configuração incompleta	Teste local + secret no Pages
P2 - curto	Revisar baseline externo	Deriva de edge/GitHub	Acesso autorizado aos painéis

Checklist pós-correção

• Todos os 217 testes Python e 43 testes JavaScript continuam passando; check sintático do site sem erros.

• Rajadas de feedback/view/cliques recebem limitação e não alteram ranking/visibilidade além da política.

• Corpos acima do limite, inclusive sem Content-Length, retornam 413 antes do parse e sem escrita.

• pnpm audit não reporta GHSA-rgj7-g3m4-5g8c; lockfile instalado com frozen-lockfile.

• Actions usam SHA completo, e atualização automatizada abre PR revisável.

• Teste de DNS rebinding não alcança IP privado; hosts de imagem esperados continuam funcionando.

• GET Meta falha com secret ausente e só aceita token correto; POST continua validando HMAC.

• Cloudflare/GitHub: HSTS, rate limiting, secret scanning, branch protection e rotação documentados sem expor valores.

• Executar nova auditoria de regressão e revisar especificamente novos handlers/migrations.

ISSUES PARA GITHUB

Textos prontos para copiar. Cada issue preserva contexto, aceite e testes esperados. Nenhuma foi criada automaticamente.

[Security] Impedir supressão automatizada de ofertas via feedback público

```
Contexto
O endpoint POST /api/feedback confia em Origin/Sec-Fetch-Site e incrementa uma contagem global. Cinco
relatos expired ocultam a oferta. Clientes não navegador podem forjar esses cabeçalhos e repetir IDs
públicos.

Risco
Integridade e disponibilidade do catálogo (CWE-799 / OWASP API6:2023). Severidade: média.

Escopo mínimo
- Aplicar rate limit no edge.
- Deduplicar feedback em janela server-side sem armazenar dado pessoal permanente.
- Remover a supressão automática baseada apenas em contagem bruta ou incluir janela/confiança/revisão.
- Tratar Origin apenas como defesa de navegador.

Critérios de aceite
- Repetições da mesma origem lógica não avançam o limiar.
- Rajadas recebem 429 ou são descartadas sem escrita.
- Oferta válida não some após cinco requisições simples.
- Testes cobrem expired, available, ID inexistente e concorrência.

Validação
Rodar testes do site e teste de rajada em staging/local; conferir contagem D1 e visibilidade.
```

[Security] Tornar métricas e contadores de clique resistentes a automação

```
Contexto
/api/view e os redirects públicos escrevem no D1 a cada chamada válida. Não há deduplicação/rate limit
versionado, e os números alimentam relatórios e popularidade.

Risco
Envenenamento de métricas/ranking e amplificação de custo D1 (CWE-799 / OWASP API4:2023). Severidade:
média.

Escopo mínimo
- Rate limit/bot management no edge.
- Deduplicação/agregação por janela com privacidade.
- Separar sinais não confiáveis do ranking.
- Exigir application/json e usar readJsonLimited em /api/view.

Critérios de aceite
- Rajadas não geram uma escrita por requisição.
- Repetições na janela não elevam ranking.
- Corpo inválido/grande é rejeitado antes do parse.
- Tráfego normal mantém redirecionamento e métricas agregadas.

Validação
Teste de carga pequeno em staging/local e comparação dos contadores D1 antes/depois.
```

[Security] Atualizar Wrangler/miniflare para eliminar sharp vulnerável

```
Contexto
O pnpm-lock fixa sharp 0.35.2 via wrangler/miniflare. O registry reporta GHSA-rgj7-g3m4-5g8c para sharp
<0.35.4. A dependência é dev/CI, não runtime do Worker.

Risco
Comprometimento/DoS do ambiente dev/CI se conteúdo aplicável alcançar libheif. Severidade de projeto:
média.

Escopo mínimo
- Atualizar Wrangler/miniflare ou aplicar override compatível para sharp >=0.35.4.
- Regenerar lockfile preservando hashes.
- Revisar changelog e compatibilidade.

Critérios de aceite
- pnpm audit sem o advisory.
- Instalação com lockfile congelado passa.
- 43 testes JS e node --check do site passam.

Validação
Anexar saída resumida do audit sem dados sensíveis e o resultado dos testes.
```

[Security] Fixar GitHub Actions por SHA imutável

```
Contexto
Os workflows usam tags mutáveis de checkout, setup-python, setup-node e upload-artifact.

Risco
Alteração upstream da referência pode executar código diferente do revisado, inclusive em job com secrets.
CWE-829. Severidade: baixa.

Escopo mínimo
- Substituir tags por SHAs completos de releases oficiais verificados.
- Manter comentário com versão semântica.
- Configurar atualização automatizada por PR.

Critérios de aceite
- Toda referência uses externa está em SHA de 40 caracteres.
- SHAs correspondem aos releases desejados.
- Workflows e testes passam com as mesmas permissões mínimas.
```

[Security] Aplicar limite real ao corpo de /api/feedback

```
Contexto
O endpoint checa Content-Length, mas chama request.json() diretamente. O cabeçalho pode ser omitido ou
subestimado.

Risco
Consumo excessivo de memória/CPU por requisição (CWE-400). Severidade: baixa.

Escopo mínimo
- Usar readJsonLimited(request, 2048).
- Manter Content-Length apenas como fast-fail.

Critérios de aceite
- Corpo >2 KiB sem Content-Length retorna 413.
- Cabeçalho subestimado também retorna 413.
- Nenhuma escrita D1 ocorre nesses casos.
- Fluxos válidos continuam funcionando.
```

[Security] Fechar janela de DNS rebinding no download de imagem

```
Contexto
A URL é resolvida/validada e depois requests.get resolve o hostname novamente. A explorabilidade depende de host controlável vindo do marketplace e acesso interno do runner.

Risco
SSRF condicional por DNS rebinding (CWE-918). Severidade preliminar: média; precisa de confirmação.

Escopo mínimo
- Inventariar hosts/CDNs oficiais e aplicar allowlist por origem.
- Se hosts arbitrários forem necessários, conectar ao IP validado preservando TLS/SNI e revalidar a conexão.

Critérios de aceite
- Teste de rebinding não alcança IP privado.
- URLs oficiais continuam válidas.
- Redirecionamentos permanecem desativados e limite de 1 MiB preservado.
```

[Security] Fazer verificação GET do webhook Meta falhar com secret ausente

```
Contexto
secureEqual normaliza valores ausentes para vazio. Se META_WEBHOOK_VERIFY_TOKEN não estiver configurado e a requisição omitir token, o handshake pode aceitar challenge.

Risco
Bypass do segredo no cenário de implantação incompleta (CWE-306). Severidade: baixa; precisa confirmar configuração do Pages.

Escopo mínimo
- Exigir secret e token não vazios antes da comparação.
- Validar configuração obrigatória no deploy/health check.

Critérios de aceite
- Secret ausente sempre retorna 403.
- Token ausente/incorreto retorna 403.
- Token correto retorna challenge.
- POST continua exigindo HMAC válido.
```

[Security] Documentar e verificar baseline de Cloudflare/GitHub

```
Contexto
WAF/rate limits, HSTS, secrets implantados, secret scanning e branch protection são externos ao repositório e não puderam ser confirmados.

Risco
Deriva de configuração e redução das defesas em profundidade. Severidade preliminar: baixa; precisa de confirmação.

Escopo mínimo
- Verificar controles em sessão autorizada.
- Documentar nomes/status/datas sem copiar IDs pessoais ou valores secretos.
- Definir owner e periodicidade de revisão.

Critérios de aceite
- Evidência não sensível para HSTS, rate limits, secret scanning e branch protection.
- Variáveis obrigatórias validadas e secrets com rotação registrada.
- Nenhum valor de secret em issue/log.
```

Referências técnicas

• OWASP Top 10 (2021) e OWASP API Security Top 10 (2023).

• CWE-79, CWE-89, CWE-306, CWE-400, CWE-799, CWE-829, CWE-918 e CWE-1104.

• Cloudflare Workers Best Practices: developers.cloudflare.com/workers/best-practices/workers-best-practices/.

• Cloudflare D1 prepared statements: developers.cloudflare.com/d1/worker-api/prepared-statements/.

• GitHub Advisory Database: GHSA-rgj7-g3m4-5g8c (sharp/libheif).

• PyPI Advisory Database consultada por pip-audit 2.10.1 em Python 3.12.

Declaração final

Este relatório descreve o estado observável da referência Git auditada na data indicada. Achados condicionais não devem ser promovidos a vulnerabilidades confirmadas sem a verificação externa indicada. Da mesma forma, controles externos não comprovados não foram tratados como ausentes. A remediação deve ocorrer em mudança separada, revisada e testada.